

Social Engineering Attacks

◆ What Is Social Engineering?

Social Engineering is the act of manipulating, tricking, or influencing individuals to reveal confidential information, perform unauthorized actions, or give access to systems. Instead of attacking technology directly, attackers exploit human psychology, trust, fear, urgency, or curiosity.

Common Targets

- Technical support staff
 - Help desk employees
 - System administrators
 - Employees with limited security awareness
-

◆ Impact of Social Engineering on Organizations

Social engineering can cause:

- **Economic losses**
 - **Permanent or temporary shutdown**
 - **Loss of privacy**
 - **Damage to brand reputation**
-

◆ Phases of a Social Engineering Attack

Attackers typically follow a sequence:

1. **Research (Reconnaissance)**

Dumpster diving, website scanning, employee details.

2. **Victim Selection**

Usually frustrated or low-awareness employees.

3. **Relationship Building**

Using trust or authority tactics.

4. Exploitation

Collect passwords, financial data, or access permissions.

◆ Types of Social Engineering Attacks

Based on the source, attacks are categorized into:

- **Human-Based**
- **Computer-Based**
- **Mobile-Based**

1 Human-Based Social Engineering

Attack Type	Description	Example	Impact	Prevention
Impersonation	Attacker pretends to be a legitimate person	Posing as IT staff asking for password	Unauthorized access	Always verify identity, follow authentication policy
Vishing (Voice Phishing)	Using calls or voice technology to extract data	Fake bank support call	Financial loss, account takeover	Avoid sharing info over calls, verify source
Eavesdropping	Unauthorized listening to communication	Listening to employees discussing credentials	Exposure of private or classified data	Avoid discussing sensitive info in public
Shoulder Surfing	Observing someone entering PIN/password	Watching someone type ATM PIN	Credential theft	Use privacy screens, cover keypad
Dumpster Diving	Searching through trash for valuable information	Finding old password printouts or billing info	Leakage of credentials or banking details	Shred documents before disposal
Tailgating	Entering a secure area by following	Attacker walks in behind an employee	Physical breach	Access control, turnstiles,

Attack Type	Description	Example	Impact	Prevention
	someone without identity			awareness training
Piggybacking	Employee knowingly allows unauthorized person entry	"I forgot my badge, let me in."	Bypass security controls	Enforce strict badge policies

2 Computer-Based Social Engineering

Type	Description	Example	Prevention
Pop-Up Attacks	Fake update or warning messages	"Your browser is outdated — install now."	Use pop-up blockers, validate official software
Spam Emails	Unsolicited bulk messages to trick users	Fake lottery or discount emails	Email filters, avoid unknown links
Instant Messaging Attacks	Attack via chat apps to collect info	Fake HR asking for DOB, address	Verify sender identity
Phishing	Trick users into revealing sensitive info	Fake bank login page	Awareness training, MFA

Detailed Sub-Types of Phishing

Sub-Type	Explanation	Example
Email Phishing	Mass-sent fake emails pretending to be legitimate	Fake PayPal verification request
Spear Phishing	Targeted attack on a specific user with personalized content	Email referencing employee project details
Whaling	Targets VIPs such as CEOs, CFOs	Fake legal subpoena sent to CEO
Malware-Based Phishing	File attachments contain malware	PDF invoice containing trojan
Search Engine (SEO) Phishing	Fake website ranked in search results	Fake banking website

3 Mobile-Based Social Engineering

Type	Description	Example
Malicious App Publishing	Fake security or utility apps steal data	Battery saver app stealing contacts
Repackaged Apps	Modified legitimate apps with malware	Modified WhatsApp clone
SMS Phishing (Smishing)	Fake text messages to steal sensitive data	Fake OTP verification link

◆ Identity Theft

Identity theft occurs when a criminal steals someone's personal information such as Aadhaar number, SSN, PAN, phone number, or banking credentials to commit fraud.

Types of Identity Theft

Type	Description
Financial Identity Theft	Using victim's bank info to steal money
Medical Identity Theft	Using insurance to get treatment
Child Identity Theft	Using identity of minors
Tax Identity Theft	Filing fraudulent tax refunds
Driver's License Identity Theft	Using someone else's ID during police stops

◆ Insider Threat / Insider Attack

An insider attack is executed by employees or trusted individuals who already have legitimate access. Common insider attackers include:

- Disgruntled employees
- Ex-staff
- Third-party vendors

Impact

- Data leaks
 - Sabotage
 - System backdoor creation
 - Intellectual property theft
-

◆ **Best Practices to Prevent Social Engineering Attacks**

- ✓ Regular cybersecurity awareness training
 - ✓ Multi-Factor Authentication (MFA)
 - ✓ Strict identity verification policies
 - ✓ Data encryption
 - ✓ Document shredding policies
 - ✓ Secure physical access controls
 - ✓ Email & spam filters
 - ✓ Zero-trust security framework
-

◆ **Conclusion**

Social engineering continues to be one of the most successful attack methods because it exploits human emotions—not technology. Understanding its forms and applying strong security policies, technical defenses, and employee awareness programs are essential to prevent damage.
